

Resilience and Compliance Strategy

Disaster Recovery, High Availability, and Compliance Design

Global Retail Platform | IBM Cloud | March 2026

Operational Targets — This Document

Availability: 99.95% uptime (≤ 4.4 hours downtime/month) **Concurrent Users:** 50,000 peak **RTO:** 4 hours **RPO:** 1 hour **Frameworks:** GDPR (EU), PCI-DSS (payment)

High availability strategy

The high availability strategy for the Global Retail Platform is designed to eliminate single points of failure across every tier of the hybrid architecture. The platform must sustain 99.95% uptime — no more than 4.4 hours of downtime per calendar month — while simultaneously supporting up to 50,000 concurrent users during peak demand events. This is achieved through a combination of multi-zone redundancy, automated failover, horizontal pod auto-scaling, and resilient traffic routing, applied consistently from the DNS layer down to individual service pods.

1.1 Multi-Zone and Multi-Region Redundancy

IBM Kubernetes Service (IKS) worker pools in US-South (Dallas) are distributed across three availability zones within the region. Each production microservice — Product, Order Processing, Customer Profile, Checkout and Payment — maintains a minimum of three pod replicas, with at least one replica scheduled in each availability zone. This configuration ensures that the failure of a single zone does not interrupt service availability; remaining replicas in healthy zones continue to serve traffic while Kubernetes reschedules replacement pods.

At the regional level, the IBM Cloud Frankfurt region runs active-standby deployments of all core microservices. Under normal operation, all production traffic is served from US-South. If a US-South regional health check fails, IBM Cloud Internet Services (CIS) automatically updates DNS routing to direct traffic to the Frankfurt standby within the 60-second TTL window, satisfying the RTO 4-hour objective with significant headroom.

Redundancy Configuration Summary

- IKS worker pools: 3 availability zones per region, minimum 2 worker nodes per zone
- Product and Checkout services: baseline 3 replicas, scaling to 20 replicas under sustained load
- Database tier: IBM Cloud Databases for PostgreSQL with synchronous replication across 3 zones

- Redis cache: IBM Databases for Redis HA cluster with automatic leader election on primary failure
- EU Frankfurt region: active-standby microservice deployments for all customer-facing services

1.2 Horizontal Pod Auto-Scaling

The IKS Horizontal Pod Autoscaler (HPA) is configured for all customer-facing services. HPA monitors CPU utilization and requests-per-second (RPS) metrics, scaling pod counts upward when thresholds are breached and downward during off-peak periods to control cost. During Black Friday and seasonal sales events, the Product and Checkout services scale from their baseline of 3 replicas to a maximum of 20 replicas within 90 seconds of a sustained threshold breach.

Service	Baseline Replicas	Max Replicas	Scale-Up Trigger	Scale-Down Delay
Product Microservice	3	20	CPU > 65% or RPS > 500 for 60s	5 minutes
Checkout & Payment API	3	15	CPU > 60% or RPS > 300 for 60s	10 minutes
Order Processing Service	3	12	CPU > 70% for 60s	5 minutes
Customer Profile Service	2	10	CPU > 70% for 60s	5 minutes
API Gateway	3	20	Connections > 8,000 for 30s	5 minutes

1.3 Load Balancing and Traffic Routing

Traffic is distributed across a four-layer routing stack that applies routing intelligence at each level, from global DNS resolution through to individual pod selection. Each layer contributes independently to availability — failure or saturation at one layer does not propagate to layers below it.

Layer	Component	Mechanism	Availability Contribution
DNS / Global	IBM Cloud Internet Services (CIS)	Anycast DNS with health-check-driven global load balancing; 60-second regional failover	Routes users to the nearest healthy region; prevents single-region failures from affecting all users
Regional	IBM Cloud Application Load Balancer	HTTP/HTTPS path-based routing across IKS node pools; health probes every 10 seconds	Removes unhealthy nodes from rotation within 30 seconds; enables zero-downtime deployments
Cluster	Kubernetes Ingress (NGINX)	TLS termination; Host/path routing to ClusterIP	Isolates service blast radius; a failing service

Layer	Component	Mechanism	Availability Contribution
		services; pod-level NetworkPolicy	does not affect routing to healthy services
East-West	Istio Service Mesh	mTLS; per-service circuit breakers; retry policies with exponential back-off; distributed tracing	Prevents cascading failures; automatically retries transient errors before surfacing them to the caller

1.4 Zero-Downtime Deployment Strategy

All production deployments use a rolling update strategy with maxUnavailable=0 and maxSurge=1, as defined in the Kubernetes deployment manifest and enforced by the CI/CD pipeline. This configuration guarantees that the platform maintains full replica capacity throughout every deployment: a new pod is brought to a Ready state before its predecessor is terminated. The post-deployment health check in the CI/CD pipeline verifies that the updated service returns HTTP 200 on the /products endpoint within 300 seconds; if the check fails, kubectl rollout undo is triggered automatically, reverting the deployment to the last known-good image.

Deployment Safety Controls

- Rolling update: maxUnavailable=0, maxSurge=1 — full capacity maintained throughout rollout
- Readiness probe: HTTP GET /health — pod only receives traffic after passing probe
- Liveness probe: HTTP GET /health every 10s — unhealthy pods are restarted automatically
- Rollback trigger: non-200 HTTP response on health check within 300s of deployment
- Approval gates: manual sign-off from DevOps Lead + QA Lead before Staging; three-role approval before Production

1.5 Circuit Breaking and Fault Isolation

Istio circuit breakers are configured for all inter-service communication paths in the Application Services Zone. When an upstream service returns errors at a rate exceeding the configured threshold, the circuit breaker opens and subsequent requests are immediately rejected with a 503 response rather than queuing and timing out. This prevents a degraded dependency from consuming thread pool capacity in the calling service and cascading the failure across the service mesh. Combined with retry policies configured with exponential back-off and jitter, transient errors are absorbed without user-visible impact under normal load, while sustained failures are isolated to the affected service boundary.

Disaster recovery strategy

The disaster recovery strategy defines how the Global Retail Platform detects, responds to, and recovers from major infrastructure failures — including regional cloud outages, data center disruptions, and catastrophic data loss events. The strategy is designed around two quantified recovery objectives established in the non-functional requirements: a Recovery Time Objective (RTO) of four hours and a Recovery Point Objective (RPO) of one hour. Every backup, replication, and failover mechanism in this strategy is selected and configured to meet or exceed these targets.

Recovery Time Objective (RTO)	4 hours — maximum acceptable time from failure detection to full service restoration
Recovery Point Objective (RPO)	1 hour — maximum acceptable data loss window; no more than 60 minutes of transactions may be unrecoverable
Primary Region	IBM Cloud US-South (Dallas) — all production traffic under normal operation
DR Region	IBM Cloud EU-Central (Frankfurt) — active-standby deployments; DNS failover target
Failover Trigger	CIS regional health check failure sustained for > 2 minutes
Failover Method	Automated CIS DNS update + IBM Satellite orchestrated workload promotion
DR Test Cadence	Full failover drill conducted quarterly; partial recovery test monthly

2.1 Backup Strategy

Data backup is implemented at three levels: database snapshots, cross-region object storage replication, and container image registry redundancy. Each mechanism is aligned to the specific data type and its RPO contribution.

Data Asset	Backup Mechanism	Frequency	Retention	RPO Contribution
PostgreSQL transaction DB	IBM Cloud Databases automated snapshots + WAL archiving to COS	Continuous (WAL) + daily snapshot	30 days	< 15 minutes
Inventory & order state	Block storage snapshots replicated to Frankfurt COS bucket	Every 15 minutes	7 days	< 15 minutes
EU Customer PII DB (Frankfurt)	Automated daily backup within Frankfurt region; no cross-region transfer (GDPR)	Daily	90 days	< 24 hours (PII only)

Data Asset	Backup Mechanism	Frequency	Retention	RPO Contribution
Redis session cache	Redis AOF persistence + snapshot to COS every 5 minutes	Every 5 minutes	24 hours	< 5 minutes
Container images	IBM Container Registry mirrored to Frankfurt registry namespace	On every push	90 days	N/A — stateless
Build artifacts & SBOM	IBM COS Standard tier with cross-region replication	On every pipeline run	1 year	N/A — audit evidence
Application & audit logs	IBM COS immutable bucket (WORM) with cross-region replication	Real-time streaming	7 years	N/A — append-only

2.2 Replication Architecture

Active data replication between US-South and EU-Frankfurt ensures that the standby region maintains a data state that is no more than 60 minutes behind production at any point. IBM Cloud Object Storage cross-region replication handles unstructured and semi-structured data asynchronously. PostgreSQL WAL (Write-Ahead Log) shipping via IBM Cloud Databases provides near-real-time transactional data replication with a typical lag of under 15 minutes under normal load.

Replication Topology

- PostgreSQL (primary): US-South — WAL shipped to standby replica in Frankfurt every 15 minutes; promotes automatically on primary failure
- IBM COS (all buckets): Cross-region replication enabled; objects replicated to Frankfurt bucket within 5 minutes of write
- IBM Container Registry: Images mirrored to eu.icr.io namespace on every push; no manual synchronization required
- Redis: No cross-region replication (ephemeral cache); warm-up from PostgreSQL on DR activation takes < 5 minutes
- On-premises data: IBM Satellite agent streams inventory and order events to cloud event log; last 60 minutes recoverable from IBM Event Streams

2.3 Recovery Procedure

The following procedure defines the sequence of steps executed when a US-South regional failure is confirmed. The procedure is automated where possible via IBM Satellite runbook automation; manual steps require authorization from the DevOps Engineering Lead and are documented for audit purposes.

Step	Action	Owner	Tool / Mechanism	Target Time
1	Detect failure: CIS health check returns non-200 for 3	Automated	IBM CIS health monitoring	T+0:02

Step	Action	Owner	Tool / Mechanism	Target Time
	consecutive probes over 2 minutes			
2	Alert fired to on-call SRE via PagerDuty; incident channel opened in Slack	Automated	IBM Cloud Monitoring + PagerDuty integration	T+0:03
3	Confirm regional outage scope; rule out application-level cause	SRE On-Call	IBM Cloud Monitoring dashboards	T+0:15
4	Authorize DR activation; notify DevOps Lead and VP E-Commerce	SRE Lead	Incident management runbook	T+0:20
5	CIS DNS failover executes: traffic redirected to Frankfurt standby	Automated	IBM CIS DNS failover rule	T+0:22
6	IBM Satellite promotes Frankfurt standby services to active; scales HPA to full capacity	Automated	IBM Satellite runbook automation	T+0:45
7	PostgreSQL standby promoted to primary in Frankfurt; application connection strings updated	Automated	IBM Cloud Databases automated promotion	T+1:00
8	Smoke tests executed against Frankfurt endpoints; HTTP 200 confirmed on all critical paths	Automated	CI/CD pipeline smoke test suite	T+1:15
9	Incident declared resolved; stakeholder notification sent via Slack and email	SRE Lead	Slack webhook + email distribution list	T+1:30
10	Post-incident review scheduled; runbook updated with lessons learned	DevOps Lead	Confluence incident template	T+48:00

Based on this procedure, the expected RTO is approximately 1 hour 30 minutes under normal DR conditions — well within the 4-hour RTO target. This margin provides buffer for steps that require manual authorization or take longer than expected under degraded conditions.

2.4 DR Testing and Validation

A disaster recovery strategy that has not been tested is not a recovery strategy — it is a hypothesis. The following testing cadence is mandatory and must be completed and documented before each major trading event (Black Friday, seasonal sales launches).

Test Type	Frequency	Scope	Success Criteria	Priority
Full regional failover drill	Quarterly	Complete failover from US-South to Frankfurt; all services promoted; smoke tests pass	RTO achieved in < 4h; RPO confirmed < 1h; zero data loss beyond threshold	Critical
Partial failover — single zone	Monthly	Simulate loss of one availability zone within US-South; verify HPA and pod rescheduling	No user-visible errors; pod rescheduling completes in < 5 minutes	Critical
Database point-in-time restore	Monthly	Restore PostgreSQL to a specific point-in-time snapshot in an isolated environment	Restore completes within 30 minutes; data integrity verified against checksum	Critical
Backup integrity check	Weekly	Verify that all COS backup objects are readable and checksums match the source	100% of backup objects verified; no corruption detected	Mandatory
Runbook walkthrough review	Quarterly	SRE team walks through DR runbook and identifies gaps or outdated steps	Runbook updated and approved by DevOps Lead	Mandatory

Identity and access management

Identity and Access Management (IAM) controls define who can access platform resources, under what conditions, and with what level of privilege. For the Global Retail Platform, IAM is a foundational compliance control that satisfies requirements from both GDPR (access to EU customer personal data must be restricted to authorized roles with a documented business need) and PCI-DSS (access to cardholder data environments must be tightly scoped and audited). All IAM policies follow the principle of least privilege: identities are granted only the permissions required to perform their defined function, and those permissions are reviewed and re-certified regularly.

3.1 Role-Based Access Control

IBM Cloud Identity and Access Management enforces role-based access control across all cloud resources. Human identities are managed through IBM Cloud IAM federated with the organization's existing identity provider via SAML 2.0, enabling single sign-on while centralizing authentication policy (MFA enforcement, session timeout, password policy) in the enterprise IdP. Service-to-service communication within the Kubernetes cluster uses Kubernetes ServiceAccount tokens bound to RBAC roles with the minimum API permissions required for each workload.

Role	Scope	Permissions	MFA Required	Review Cadence
DevOps Engineer	CI/CD pipeline, IKS clusters (non-prod)	Deploy to Dev and Staging; view Production logs; no Production kubectl exec	Yes	Quarterly

Role	Scope	Permissions	MFA Required	Review Cadence
DevOps Lead	All IKS clusters, IBM Toolchain	Approve Staging and Production deployments; kubectl access to all namespaces; pipeline configuration	Yes	Quarterly
Security & Compliance Director	Read-only across all environments	View all audit logs, scan reports, IAM policies; approve Production deployments; no write access	Yes	Quarterly
SRE On-Call	Production cluster (read + limited write)	kubectl get/describe/logs; rollback authorization; no config changes; incident response only	Yes	Monthly
Application Service Account	Own namespace only	Read ConfigMaps and Secrets in own namespace; no cross-namespace access; no cluster-level permissions	N/A	On change
CI/CD Pipeline Agent	IBM Container Registry, IKS deploy API	Push images to ICR; kubectl set image in target namespace; read build secrets from Secrets Manager	N/A — API key	Quarterly
Data Analyst (Read-Only)	Observability dashboards only	Read IBM Cloud Monitoring dashboards; no access to raw log data containing PII; no cluster access	Yes	Quarterly

3.2 Least-Privilege Enforcement

Least privilege is enforced at four layers: IBM Cloud IAM resource group policies, Kubernetes RBAC within IKS clusters, Kubernetes NetworkPolicy for pod-to-pod communication, and Istio AuthorizationPolicy for service mesh traffic. Each layer independently restricts access, so a misconfiguration at one layer does not automatically grant access through another.

Layer	Mechanism	What It Restricts	Enforcement Point
Cloud Resource Access	IBM Cloud IAM resource group policies + access groups	Which identities can manage cloud services (IKS, COS, ICR, Secrets Manager)	IBM Cloud IAM control plane
Kubernetes API	Kubernetes RBAC (Role + RoleBinding per namespace)	Which ServiceAccounts and human users can call the Kubernetes API and with which verbs	kube-apiserver admission

Layer	Mechanism	What It Restricts	Enforcement Point
Network (pod-to-pod)	Kubernetes NetworkPolicy (default-deny per namespace)	Which pods may initiate TCP connections to which other pods, on which ports	Calico CNI policy engine
Service Mesh (L7)	Istio AuthorizationPolicy (per-service allow-list)	Which source service principals may call which HTTP methods on which paths	Istio sidecar proxy
Secrets Access	IBM Secrets Manager with IAM-scoped service IDs	Which workloads may retrieve which named secrets; rotation managed by Secrets Manager	IBM Secrets Manager API

3.3 Identity Federation and Single Sign-On

Human access to IBM Cloud is federated through the organization's enterprise identity provider (IdP) via SAML 2.0. This means that IBM Cloud IAM trusts the enterprise IdP to authenticate users; no separate IBM Cloud passwords are maintained for human identities. Multi-factor authentication (MFA) is enforced at the IdP layer for all users, and session tokens issued by IBM Cloud IAM are valid for a maximum of 8 hours before re-authentication is required. This approach ensures that MFA policy, account lifecycle management, and access revocation are controlled from a single authoritative source — the enterprise IdP — reducing the risk of orphaned accounts following employee offboarding.

Federation Configuration Requirements

- SAML 2.0 federation between enterprise IdP (Azure AD / Okta) and IBM Cloud IAM
- MFA enforced at IdP layer for all users: TOTP or hardware security key (FIDO2) required
- Session token maximum lifetime: 8 hours for human users; 1 hour for CI/CD service IDs
- Automatic account deprovisioning: IdP lifecycle event triggers IBM Cloud IAM access revocation within 1 hour
- Privileged access (Production approval roles): requires just-in-time elevation with DevOps Lead co-authorization

3.4 Access Reviews and Certification

All role assignments are subject to a formal access review process. Quarterly access certification campaigns require role owners to review and re-confirm every active permission assignment within their scope. Any assignment not explicitly re-certified within the campaign window is automatically revoked. Access to Production environments and PCI-DSS-scoped resources is reviewed monthly. All review decisions — approvals and revocations — are recorded in the immutable IBM COS audit log and are available for inspection by the Security and Compliance Director and external auditors.

Data protection

Data protection controls ensure that customer personal data, payment information, and operational records are secured against unauthorized access, accidental exposure, and regulatory non-compliance. The Global Retail Platform operates under two primary regulatory frameworks — GDPR for EU customer data and PCI-DSS for payment card data — each with distinct and non-overlapping data protection requirements. The controls described in this section satisfy both frameworks simultaneously through a layered approach: data residency enforcement, encryption at rest and in transit, key lifecycle management, and data classification.

4.1 Data Classification

All data processed by the platform is classified into one of four tiers. Classification determines the encryption standard, storage location, access control level, and retention policy applied to that data. Classification is assigned at the point of data creation and is propagated through all downstream storage and processing systems.

Classification	Examples	Encryption	Location Constraint	Access Control
Restricted — PCI	Payment card numbers, CVVs, cardholder names, PANs	AES-256 at rest; TLS 1.3 in transit; HSM key management	On-premises PCI scope only; never in cloud logs or databases	PCI role only; MFA + audit log on every access
Restricted — PII	EU customer names, email, address, order history	AES-256 at rest; TLS 1.3 in transit	IBM Cloud Frankfurt (EU) or on-prem EU DC only; GDPR residency enforced	Data custodian role; purpose-limited access; DSAR-capable
Confidential	Internal pricing, supplier contracts, inventory thresholds	AES-256 at rest; TLS 1.3 in transit	Any approved environment	Internal roles only; no third-party access
Internal	Application logs (non-PII), build artifacts, config files	AES-256 at rest; TLS in transit	Any approved environment	Authenticated users; read-only for most roles

4.2 Encryption at Rest

All data stored by the platform — across IBM Cloud Block Storage, Object Storage, File Storage, and managed databases — is encrypted at rest using AES-256. Encryption is enforced at the storage layer, meaning that data is encrypted before it is written to physical media, regardless of the application writing it. This provides protection against physical media theft and unauthorized storage-layer access.

Storage Type	Technology	Encryption Standard	Key Management
PostgreSQL transaction DB	IBM Cloud Databases for PostgreSQL	AES-256 (storage layer)	IBM Key Protect — customer-managed root key; envelope encryption
Block storage (inventory, PII)	IBM Cloud Block Storage	AES-256 (provider-managed + BYOK option)	IBM Key Protect; PII volumes use customer-managed keys exclusively
Object storage (COS)	IBM Cloud Object Storage	AES-256 (SSE-C for restricted data)	IBM Key Protect; restricted buckets require customer-managed keys
Payment token vault	On-premises HSM-backed block volumes	AES-256 + HSM hardware key protection	On-prem HSM (FIPS 140-2 Level 3); keys never leave HSM boundary
Redis session cache	IBM Databases for Redis	AES-256 (storage layer)	IBM Key Protect; session tokens are short-lived (< 8h TTL)
Kubernetes Secrets	IKS etcd (encrypted at rest)	AES-256 (etcd encryption provider)	IBM Key Protect root key; Secrets Manager wraps all application secrets

4.3 Encryption in Transit

All data in motion between any two components of the platform — whether between a customer's browser and the API gateway, between microservices within the cluster, or between the on-premises data center and IBM Cloud — is encrypted using current industry-standard protocols. No plaintext data paths are permitted anywhere in the architecture.

Traffic Path	Protocol	Certificate Authority	Notes
Customer browser → IBM CIS / CDN	TLS 1.3	IBM CIS managed certificate (Let's Encrypt)	TLS 1.0 and 1.1 disabled; TLS 1.2 permitted for legacy clients only
CIS → API Gateway (IKS Ingress)	TLS 1.3	cert-manager (Let's Encrypt / internal CA)	Full end-to-end TLS; no TLS termination at CIS for API paths
API Gateway → microservices	mTLS (Istio)	Istio mesh CA (SPIFFE/SPIRE)	Mutual TLS for all service mesh traffic; certificates rotated every 24 hours
Microservice → microservice	mTLS (Istio)	Istio mesh CA	AuthorizationPolicy enforces per-path allow-list;

Traffic Path	Protocol	Certificate Authority	Notes
			unauthorized calls rejected at proxy
Microservice → IBM Cloud DB	TLS 1.3	IBM Cloud internal CA	Private service endpoint; traffic never traverses public internet
IBM Cloud → on-premises (Direct Link)	Private circuit (no TLS required)	N/A — private circuit	Direct Link is private by design; no encryption overhead on primary path
IBM Cloud → on-premises (VPN failover)	IPSec IKEv2 + AES-256-GCM	Pre-shared key + certificate	VPN activates automatically on Direct Link failure; matches encryption NFR-04
Partner / 3PL API → API Gateway	TLS 1.3 + mTLS	Organization PKI (certificate pinning)	mTLS certificate pinning ensures only authorized partners can connect

4.4 Data Residency and GDPR Compliance

GDPR requires that EU customer personal data be processed and stored within geographic boundaries approved under the regulation. The architecture enforces this requirement through a combination of IBM Cloud region selection, IAM policy, and architectural isolation — not through documentation alone.

EU Data Residency Enforcement Mechanisms

- All IBM Cloud resources that process EU customer PII are provisioned exclusively in the Frankfurt (eu-de) region
- IBM Cloud IAM policies block cross-region data transfer API calls from the EU Compliance Zone (10.1.0.0/16)
- Network-level controls prevent COS replication of PII buckets to any non-EU bucket; replication is configured to EU-only targets
- IBM Cloud Object Storage retention policies prevent deletion of EU customer records within their legally mandated retention window
- EU Customer Profile Service API supports Data Subject Access Requests (DSAR): export, rectification, and erasure endpoints are implemented and logged
- Data Processing Agreements (DPAs) are established with IBM Cloud as a data processor; IBM Frankfurt region is covered under EU Standard Contractual Clauses

4.5 PCI-DSS Payment Data Isolation

Payment card data is the most sensitive data class on the platform. PCI-DSS requires that cardholder data be handled only within a defined, isolated Cardholder Data Environment (CDE). The architecture isolates the CDE through a dedicated Kubernetes namespace (Payment Isolation Zone, 10.0.20.0/24) with NetworkPolicy enforcing default-deny ingress and egress, allowing only the minimum traffic paths required for payment processing.

PCI-DSS Requirement	Architectural Control	Implementation Detail
Isolate cardholder data environment	Dedicated IKS namespace with NetworkPolicy default-deny	Only API Gateway may connect inbound; only approved payment processors may be reached outbound
Encrypt cardholder data at rest	On-premises HSM vault; payment tokens never written to cloud storage	HSM FIPS 140-2 Level 3; tokens are single-use references; no PAN stored in cloud
Encrypt data in transit	TLS 1.3 for all payment processor connections	Certificate pinning for payment processor endpoints; TLS 1.2 permitted with approved cipher suites only
Restrict access to cardholder data	PCI role only; MFA + IBM Secrets Manager; no Production console access	kubectl exec prohibited in payment namespace; all access logged to immutable COS audit bucket
Log and monitor all access	Istio access logs + IBM Cloud Log Analysis + immutable COS	Every inbound and outbound connection in the payment namespace is logged; alerts fire on any anomalous destination
Regular penetration testing	Quarterly external pen test of Payment Isolation Zone	Findings remediated within 30 days (critical) or 90 days (high); evidence retained for PCI QSA audit

Logging and auditability

Logging and auditability controls provide the visibility needed to detect anomalies, investigate security incidents, validate compliance, and demonstrate to auditors that controls are operating as designed. For the Global Retail Platform, logging is not an operational afterthought — it is a compliance requirement under both GDPR (Article 30 processing records; Article 33 breach notification within 72 hours) and PCI-DSS (Requirement 10: track and monitor all access to network resources and cardholder data). All log data is treated as immutable evidence and is protected against modification or premature deletion.

5.1 Centralized Log Architecture

All log streams — application logs, Kubernetes audit logs, IBM Cloud activity tracker events, Istio access logs, and CI/CD pipeline logs — are ingested into a centralized IBM Cloud Log Analysis instance. From there, logs are simultaneously streamed to an immutable IBM Cloud Object Storage bucket (WORM — Write Once Read Many) for long-term retention and compliance archiving. This two-tier architecture ensures that logs are available for real-time operational queries through the Log Analysis UI while also being preserved in an unalterable format for audit and legal hold purposes.

Log Ingestion Pipeline

- Source: Application pods (structured JSON to stdout) → Kubernetes log collection agent (Fluent Bit) → IBM Log Analysis
- Source: Kubernetes API server audit log → IBM Log Analysis → COS immutable bucket
- Source: IBM Cloud Activity Tracker (IAM events, resource lifecycle) → Log Analysis → COS immutable bucket
- Source: Istio Envoy access logs (every inbound/outbound service request) → Log Analysis → COS immutable bucket
- Source: CI/CD pipeline stage logs (IBM Toolchain) → Log Analysis → COS archive bucket
- Retention: Log Analysis hot tier — 30 days searchable; COS immutable archive — 7 years (GDPR / PCI-DSS mandate)

5.2 Log Content Requirements

Every log entry generated by platform components must conform to a structured JSON schema that includes the mandatory fields listed below. Structured logging ensures that logs are machine-parseable for automated analysis and alerting, and that they contain sufficient context to reconstruct the sequence of events during an incident investigation.

Log Category	Mandatory Fields	Source	Retention
Application access log	timestamp, service_name, trace_id, user_id (hashed), http_method, path, status_code, response_time_ms, source_ip (masked)	Uvicorn / FastAPI request middleware	30 days hot / 7 years archive
Authentication event	timestamp, event_type, identity, source_ip, mfa_used, outcome (success/failure), ibm_iam_token_id	IBM Cloud IAM Activity Tracker	7 years (PCI-DSS Req. 10)
Data access event (PII or PCI)	timestamp, accessor_identity, data_classification, resource_id, action, business_justification, approver	IBM Cloud Activity Tracker + application layer	7 years (GDPR Art. 30 + PCI-DSS)
Kubernetes API audit	timestamp, user, verb, resource, namespace, response_code, request_uri, source_ip	kube-apiserver audit policy (RequestResponse level for sensitive verbs)	1 year hot / 7 years archive
CI/CD pipeline event	timestamp, stage_name, image_tag, git_commit, approver, scan_result, deployment_target, outcome	IBM Cloud Toolchain webhook + pipeline stage logs	1 year

Log Category	Mandatory Fields	Source	Retention
Security scan result	timestamp, scanner, image_or_repo, finding_count_by_severity, quality_gate_status, pipeline_run_id	Safety / IBM VA / SonarQube export	7 years (compliance evidence)
Network flow log	timestamp, src_ip, dst_ip, src_port, dst_port, protocol, bytes, action (allow/deny)	Istio Envoy access log + IBM Cloud VPC flow logs	90 days hot / 7 years archive

5.3 Alerting and Anomaly Detection

IBM Cloud Monitoring is configured with alert rules that fire on security-relevant events and operational anomalies. Alerts are routed to PagerDuty for on-call escalation and to a dedicated Security Alerts Slack channel. Alert thresholds are reviewed quarterly by the Security and Compliance Director and adjusted based on observed baseline behavior to minimize false-positive fatigue while maintaining sensitivity to genuine threats.

Alert	Trigger Condition	Severity	Response SLA	Routing
Unauthorized API access	HTTP 401/403 rate > 50/min from a single source IP	HIGH	15 minutes	PagerDuty + Security Slack
PCI namespace egress anomaly	Any outbound connection from payment namespace to unapproved destination	HIGH	5 minutes	PagerDuty + Security Slack + CISO
IAM privilege escalation	IBM Activity Tracker: role assignment to Production or PCI scope	HIGH	15 minutes	PagerDuty + DevOps Lead + Security Director
Service error rate spike	HTTP 5xx rate > 5% of total requests for any service over 2 minutes	MEDIUM	30 minutes	PagerDuty + DevOps Slack
Certificate expiry warning	TLS certificate expiry < 30 days on any production endpoint	MEDIUM	24 hours	DevOps Slack + email
Backup job failure	Any scheduled backup or replication job exits with non-zero status	MEDIUM	1 hour	DevOps Slack
Unusual data volume from EU zone	COS data transfer from EU Compliance Zone > 10 GB in 1 hour	HIGH	15 minutes	PagerDuty + Security Director (GDPR risk)
Container image scan failure	IBM VA or Safety scan returns HIGH/CRITICAL finding in pipeline	HIGH	4 hours	DevOps Slack + Security Slack

5.4 Audit Trail Controls

The immutability of the audit trail is a hard requirement under both GDPR and PCI-DSS. IBM Cloud Object Storage buckets designated for audit log retention are configured with Object Lock (WORM) policy set to a 7-year retention period. No identity — including IBM Cloud account owners and the Security and Compliance Director — can modify or delete objects within the retention window. This architectural control ensures that audit evidence is available and unaltered for regulatory inspection, internal investigations, and legal proceedings, regardless of any subsequent changes to access policies.

Audit Control	Mechanism	Compliance Obligation
Log immutability	IBM COS Object Lock (WORM) — 7-year retention; no delete or overwrite permitted within retention window	PCI-DSS Req. 10.5 (protect audit trails); GDPR Art. 30 (records of processing)
Log integrity verification	SHA-256 checksums computed on ingest; verified on scheduled basis by integrity check job; mismatches trigger HIGH alert	PCI-DSS Req. 10.5.1 (prevent modifications)
Access to audit logs	MFA required; read-only IAM role; all accesses to audit bucket logged in Activity Tracker (meta-audit)	PCI-DSS Req. 10.5.3 (promptly back up); GDPR accountability principle
Breach notification capability	IBM Cloud Monitoring alert fires within 5 minutes of anomaly; GDPR 72-hour notification window supported by centralized log search	GDPR Art. 33 (72-hour breach notification to supervisory authority)
Audit log availability	COS Standard tier for 30-day hot access; Smart Tier transitions to Archive after 90 days; restore from Archive within 12 hours	PCI-DSS Req. 10.7 (retain logs for at least 1 year, 3 months immediately available)
Change management audit	Every Kubernetes resource modification (kubectl apply/delete/patch) captured in kube-apiserver audit log; CI/CD deployment records tied to approver identity	PCI-DSS Req. 6.4 (change control); GDPR accountability principle

5.5 Compliance Reporting

Monthly and quarterly compliance reports are generated from the centralized log store and IBM Cloud Security and Compliance Center. These reports are shared with the Security and Compliance Director for review and are archived in the immutable COS audit bucket alongside the log data they reference. The following reports are produced on a scheduled basis:

- Monthly access certification report: all IAM role assignments across Production and PCI-scoped environments, with certification status from the most recent review cycle
- Monthly security scan summary: aggregated findings from all pipeline runs in the period, grouped by severity and service, with remediation status
- Quarterly DR test report: results of the most recent full failover drill, including achieved RTO and RPO, deviations from the runbook, and corrective actions

- Quarterly PCI-DSS compliance attestation: evidence package for the Payment Isolation Zone, including network topology, access logs, scan results, and pen test findings
- Annual GDPR processing register update: reviewed and approved record of all data processing activities involving EU customer personal data, per GDPR Article 30